

AI 인프라실 & DBA팀 기술 보고서

SQLON 시스템 관리자 및 DBA 가이드

설치 배포, 오프라인 폐쇄망 운영, DB 연동, 보안 및 플릿 관측성 구축 지침서

작성 부서 AI 인프라실 & DBA팀

발행 일자 2026년 7월 20일

문서 버전 v0.1.2

보안 구분 대외비 (Confidential)

문서 보안 등급: 대외비 (Confidential)

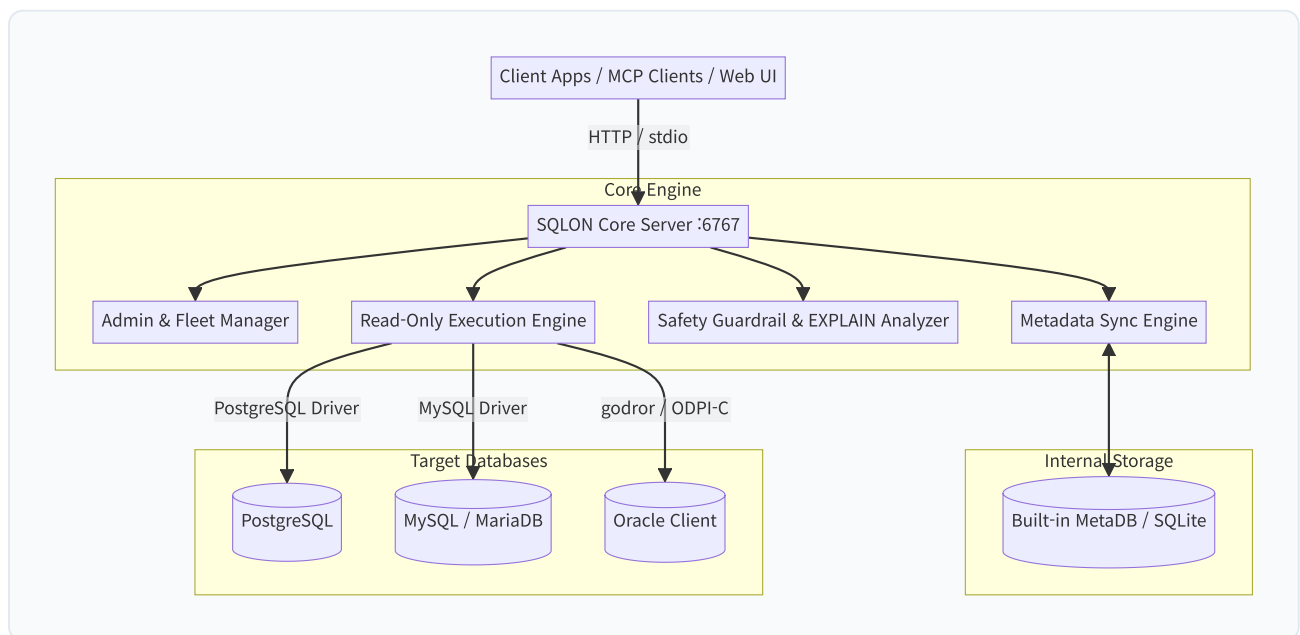
최종 수정일: 2026년 7월 20일

문서 버전: v0.1.2

대상: 시스템 관리자, 데이터베이스 관리자(DBA), DevOps 엔지니어 및 정보보안 담당자

1. 시스템 아키텍처 및 작동 원리

SQLON은 이종 멀티 데이터베이스 환경을 통합 관리하고, 자연어-SQL 변환 및 안전한 읽기 전용 실행 서비스를 제공하는 고성능 Go 기반 엔터프라이즈 마이크로서비스입니다.



지원 데이터베이스 및 요구사항

- **PostgreSQL**: v12 이상 지원 (Standard Alpine 빌드 포함)
- **MySQL / MariaDB**: MySQL v8.0+, MariaDB v10.5+ 지원 (Standard Alpine 빌드 포함)
- **Oracle**: 19c, 21c, 23c 지원 (CGO 및 Oracle Instant Client 패키징된 `sqlon-oracle` 이미지 사용)

2. 설치 및 오프라인망(폐쇄망) 배포 가이드

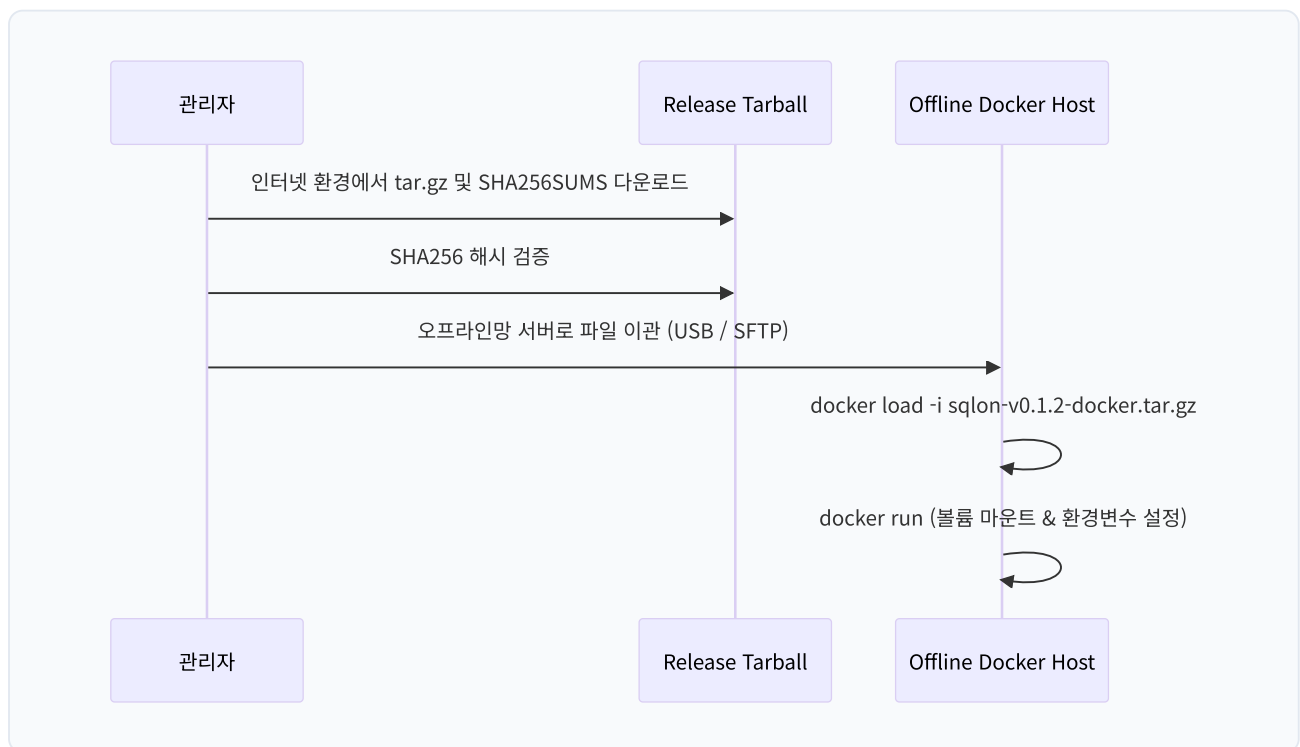
SQLON은 인터넷 연결이 불가능한 **오프라인망(Air-Gapped Network)** 환경에서도 완벽히 작동할 수 있도록 사전 구성된 독립형 도커 패키지(`.tar.gz`)를 제공합니다.

2.1 도커 이미지 패키지 구성

GitHub Release에서 제공하는 두 가지 도커 이미지 아카이브 중 요구되는 DB 환경에 맞춰 선택합니다.

배포 패키지 파일명	파일 크기	대상 DB 엔진	특징
<code>sqlon-v0.1.2-docker.tar.gz</code>	~24.4 MB	PostgreSQL, MySQL, MariaDB	경량 Alpine Linux 3.21 기반 이미지
<code>sqlon-oracle-v0.1.2-docker.tar.gz</code>	~138.1 MB	Oracle (선택적 PG/MySQL 지원)	Oracle Linux 9 slim + Instant Client 번들

2.2 오프라인망 배포 절차



Step 1. 파일 검증 및 이관

```
# SHA256 해시 검증
sha256sum -c SHA256SUMS.txt
```

Step 2. 도커 이미지 로드 (Load)

```
# 표준판 로드
docker load -i sqlon-v0.1.2-docker.tar.gz

# Oracle판 로드 시
docker load -i sqlon-oracle-v0.1.2-docker.tar.gz
```

Step 3. 컨테이너 기동 (Run)

메타데이터 지속성 및 감사 로그 보관을 위해 호스트 디렉토리를 마운트합니다.

```
mkdir -p /opt/sqlon/data /opt/sqlon/logs

docker run -d \
  --name sqlon-app \
  --restart always \
  -p 6767:6767 \
  -e SQLON_ADMIN_TOKEN="SecureMasterToken2026!" \
  -v /opt/sqlon/data:/app/data/sqlon \
  sqlon/sqlon:v0.1.2
```

3. 데이터베이스 프로파일 및 관리자 보안 설정

3.1 마스터 보안 토큰 (SQLON_ADMIN_TOKEN)

관리자 REST API 및 `/admin/db` 관리자 웹 페이지는 마스터 토큰으로 보호됩니다.

- 환경 변수 `SQLON_ADMIN_TOKEN` 을 설정하지 않으면 관리자 설정 변경 기능이 비활성화됩니다.
- API 호출 시 Header에 `Authorization: Bearer <TOKEN>` 을 전송해야 합니다.

3.2 데이터베이스 프로파일 등록 (`/admin/db` 또는 REST API)

관리자 API를 통해 대상 DB 연결 정보를 안전하게 등록합니다.

```
curl -X POST http://localhost:6767/api/fleet/instances \
  -H "Authorization: Bearer SecureMasterToken2026!" \
  -H "Content-Type: application/json" \
  -d '{
    "profile_id": "pg_analytics",
    "engine": "postgres",
    "host": "192.168.10.50",
    "port": 5432,
    "database": "dw_prod",
    "username": "sqlon_ro_user",
    "password_secret": "env:PG_PROD_PW",
    "max_open_conns": 20,
    "max_idle_conns": 5
  }'
```

IMPORTANT

비밀번호 마운트 모범 사례 비밀번호는 평문 저장을 지양하고 `env:VAR_NAME` (컨테이너 환경변수 참조) 또는 `file:/path/to/secret` (보안 파일 마운트) 방식으로 지정하십시오.

3.3 DB 계정 권한 구성 (최소 권한 원칙)

SQLON이 사용할 DB 계정은 반드시 **Read-Only** 권한만 부여되어야 합니다.

PostgreSQL

```
CREATE USER sqlon_ro WITH PASSWORD 'secure_password';
GRANT CONNECT ON DATABASE dw_prod TO sqlon_ro;
GRANT USAGE ON SCHEMA public TO sqlon_ro;
GRANT SELECT ON ALL TABLES IN SCHEMA public TO sqlon_ro;
ALTER DEFAULT PRIVILEGES IN SCHEMA public GRANT SELECT ON TABLES TO sqlon_ro;
```

MySQL / MariaDB

```
CREATE USER 'sqlon_ro'@'%' IDENTIFIED BY 'secure_password';
GRANT SELECT, SHOW VIEW ON dw_prod.* TO 'sqlon_ro'@'%' ;
FLUSH PRIVILEGES;
```

Oracle

```
CREATE USER sqlon_ro IDENTIFIED BY secure_password;
GRANT CREATE SESSION TO sqlon_ro;
GRANT SELECT ANY TABLE TO sqlon_ro;
```

3.4 MCP SSO(OAuth) — Keycloak 액세스 토큰으로 /mcp 열기

메타 DB 모드에서 /mcp 는 기본적으로 **개인 MCP 키(ssk_...)** 로만 열립니다. MCP 인가 규격(2025-06-18 이후)은 OAuth 2.1 이라, 이 기능을 켜면 OAuth 를 지원하는 MCP 클라이언트(Claude, Cursor 등)에 **MCP URL 하나만** 주어도 클라이언트가 스스로 Keycloak 로그인을 거쳐 토큰을 받아 옵니다. 키 체계는 그대로 둡니다 — 키가 필요한 자동화·폐쇄망 클라이언트는 지금처럼 키를 씁니다.

이 서버는 **리소스 서버**입니다. 로그인·토큰 발급·클라이언트 등록은 Keycloak 이 하고, sqlon 은 (1) 보호 리소스 메타데이터(RFC 9728)를 내고, (2) /mcp 의 401 에 그 위치를 알리며, (3) 제시된 토큰이 **이 서버를 위해 발급된 것인지** 검사합니다. /authorize · /token ·동적 클라이언트 등록 엔드포인트는 만들지 않습니다. 토큰을 저장하거나 세션으로 바꾸지도 않습니다.

설정 (/admin/settings → 「MCP SSO (OAuth)」 카드, 저장 즉시 적용)

설정 키	기본값	뜻	환경변수 / 플래그(기본값 총)
mcp.oauth.enabled	false	기본 꺼짐. 켜면 /mcp 가 Keycloak 액세스 토큰도 받습니다	SQLON_MCP_OAUTH_ENABLED / -mcp-oauth-enabled

설정 키	기본값	뜻	환경변수 / 플래그(기본값 총)
<code>mcp.oauth.resource</code>	빈 값	리소스 식별자(RFC 8707) = 클라이언트가 실제 접속하는 공개 MCP 주소 . 비우면 <code>oidc_redirect_url</code> 의 오리진 + MCP 경로 (<code>/mcp</code>)로 만듭니다. 요청의 <code>Host</code> 헤더는 쓰지 않습니다	<code>SQLON_MCP_OAUTH_RESOURCE</code> / <code>-mcp-oauth-resource</code>
<code>mcp.oauth.audience</code>	빈 값	공백 구분 허용 대상. 토큰의 <code>aud</code> 또는 <code>azp</code> 와 비교. 보통 Keycloak의 MCP 클라이언트 ID	<code>SQLON_MCP_OAUTH_AUDIENCE</code> / <code>-mcp-oauth-audience</code>
<code>mcp.oauth.scopes</code>	<code>mcp:read</code>	공백 구분. SSO 토큰 주체에게 주는 범위의 천장 . <code>mcp:read</code> (관리·DBA 계층 밖 모든 도구·리소스·프롬프트) <code>mcp:admin</code> (관리 도구 계층) <code>mcp:dba</code> (DBA 도구 계층). 계정 역할과의 교집합만 열립니다	<code>SQLON_MCP_OAUTH_SCOPES</code> / <code>-mcp-oauth-scopes</code>
(재사용) <code>oidc_issuer</code> · <code>oidc_redirect_url</code>	웹 로그인 설정	인증 서버와 공개 오리진은 Keycloak SSO 카드의 값을 그대로 씁니다. 새로 만들지 않습니다	

켜지는 조건은 셋이 다 있을 때입니다 — `oidc_issuer` 가 있고, 리소스 식별자를 만들 수 있고, 메타 DB 모드입니다. 하나라도 빠지면 켜 두어도 꺼진 것처럼 동작하며(메타데이터 404, 401 에 도전 헤더 없음) 카드에 「켜짐·미완성」과 이유가, 서버 로그에 `mcp oauth: enabled but inactive: ...` 가 남습니다. 잘못된 값 (`mcp.oauth.scopes` 의 모르는 낱말, 쿼리가 붙은 리소스 URL 등)은 저장 시 400 으로 거부됩니다.

카드에는 클라이언트에 줄 **MCP URL(resource)** 과 **메타데이터 주소**가 복사 단추와 함께 표시됩니다. 사용자 쪽 안내는 `/admin/keys` 의 「키 없이 SSO 로 연결하기」와 사용자 가이드 § 2.3 에 있습니다.

Keycloak 쪽 할 일

1. MCP 클라이언트용 **공개(public) 클라이언트**를 만듭니다(예: `sqlon-mcp`). Standard Flow 컴, PKCE S256, Direct Access Grants·Implicit·Service accounts 끄. **웹 로그인 클라이언트**(`oidc_client_id`)와 다른 클라이언트입니다.
2. Valid Redirect URIs 에 쓰는 MCP 클라이언트의 콜백을 **정확히** 적습니다(Claude 는 `https://claude.ai/api/mcp/auth_callback`, 로컬 클라이언트는 `http://127.0.0.1:*/callback` 류). * 하나로 다 여는 것은 금지입니다.
3. 대상(audience) — 둘 중 하나:
 - **정식 경로**: 그 클라이언트(또는 전용 client scope)에 **Audience 매퍼** 추가 — Mapper type `Audience`, Included Custom Audience = 리소스 식별자(예: `https://sqlon.example.com/mcp`), Add to access token **ON**, Add to ID token OFF.
 - **호환 경로**: 매퍼 없이 이 서버의 `mcp.oauth.audience` 에 클라이언트 ID(`sqlon-mcp`)를 적습니다. 실제 Keycloak 26 액세스 토큰은 `aud` 에 `account` 만 싣고 클라이언트 ID 는 `azp` 에 담으므로 이 값으로 통과합니다.
4. 액세스 토큰 수명은 짧게(5분 안팎). 이 서버는 introspection 을 하지 않으므로 **Keycloak 에서 로그아웃하거나 사용자를 끄더라도 이미 발급된 토큰은 만료까지 삽니다**. 즉시 차단이 필요하면 sqlon 의 사용자 비활성화(다음 요청부터 거부)를 함께 쓰세요.

사용자는 **먼저 웹 콘솔에 Keycloak(SSO) 으로 한 번 로그인**해야 합니다. 그 순간이 등록이며, 토큰의 `sub` 로 그 계정을 찾습니다. 토큰만으로는 계정을 만들지 않고, 비활성 계정을 되살리지 않으며, 토큰의 role claim 을 권한으로 옮기지 않습니다.

curl 로 확인하기

```
# 1) 메타데이터 — 인증 없이 맨 JSON (꺼져 있으면 404)
curl -s https://sqlon.example.com/.well-known/oauth-protected-resource/mcp
# {"resource":"https://sqlon.example.com/mcp","authorization_servers":["https://kc.examp
# "bearer_methods_supported":["header"],"scopes_supported":["mcp:read"],"resource_name"

# 2) 401 도전 — MCP 경로에서만 resource_metadata 가 붙습니다
curl -si -X POST https://sqlon.example.com/mcp -H 'Content-Type: application/json' \
  -d '{"jsonrpc":"2.0","id":1,"method":"tools/list"}' | grep -i www-authenticate
# WWW-Authenticate: Bearer realm="sqlon", resource_metadata="https://sqlon.example.com/.

# 3) 토큰으로 tools/list (토큰은 클라이언트가 받아 옵니다; 손으로 확인할 때만)
curl -s -X POST https://sqlon.example.com/mcp -H "Authorization: Bearer $ACCESS_TOKEN" \
  -H 'Content-Type: application/json' -H 'Accept: application/json' \
  -d '{"jsonrpc":"2.0","id":1,"method":"tools/list"}'
```

REST 경로(`/api/*`)에 같은 토큰을 보내면 401 입니다 — OAuth 토큰은 `/mcp` 에서만 받습니다.

거부 메시지별 조치

401 본문에 이유가 적히고, 하위 원인(서명·발급자·만료·대상 등)은 서버 로그 `sqlon: mcp oauth: refused: ...` 에 남습니다.

401 본문	뜻	조치
이 서버는 SSO 액세스 토큰을 받지 않습니다	<code>mcp.oauth.enabled</code> 꺼짐	카드에서 켜기
켜져 있지만 구성이 불완전합니다(...)	issuer 또는 리소스 식별자 없음	괄호 안 이유대로 <code>oidc_issuer</code> / <code>mcp.oauth.resource</code> (또는 <code>oidc_redirect_url</code>) 채우기
유효하지 않습니다(서명·발급자 키)	서명 불일치, 모르는 <code>kid</code> , <code>HS256</code> / <code>none</code> , 다른 realm 키, JWKS 조회 실패	같은 realm 으로 재로그인; 로그의 원인 확인(<code>discovery</code> / <code>jwks</code> 오류면 sqlon → Keycloak 네트워크·CA)
발급자(iss)가 ... 다릅니다	다른 realm 토큰	클라이언트가 이 서버의 메타데이터를 다시 읽도록 재연결
만료되었습니다 / 아직 유효하지 않습니다 (nbf)	수명 경과 / 시계 차이	재로그인 / 서버·Keycloak 시각 동기화
액세스 토큰이 아닙니다(typ=ID) / ID 토큰은 MCP 자격이 아닙니다	ID 토큰 또는 Refresh 토큰을 보냄	클라이언트가 <code>access_token</code> 을 보내도록 확인
소지자 증명(cnf)이 묶인 ...	DPoP/mTLS 토큰	일반 Bearer 토큰으로 발급되는 클라이언트 설정 사용
이 서버를 위해 발급된 것이 아닙니다(토큰의 <code>aud=[...]</code> , <code>azp="..."</code>)	대상 불일치 — 다른 앱용 토큰	메시지의 <code>azp</code> 값을 <code>mcp.oauth.audience</code> 에 더하거나, Audience 매퍼에 메시지의 리소스 식별자를 넣기

401 본문	뜻	조치
범위(...)와 서버가 허용한 범위(...)에 공통 항목이 없습니다	토큰이 <code>mcp:*</code> 범위를 실어 왔는데 천장과 교집합 없음	클라이언트 요청 <code>scope</code> 를 줄이거나 <code>mcp.oauth.scopes</code> 넓히기
등록되어 있지 않습니다. 먼저 웹 콘솔에 ... 로그인	이 <code>sub</code> 로 로그인한 계정 없음	사용자가 웹 콘솔에 SSO 로 한 번 로그인
이 <code>sqlon</code> 계정은 비활성 상태입니다	관리자가 끈 계정	<code>/admin/users</code> 에서 활성화
(200, 도구 결과) <code>requires SSO</code> <code>scope mcp:admin / mcp:dba</code>	천장 미달	<code>mcp.oauth.scopes</code> 에 해당 낱말 추가 (계정 역할도 필요)

4. 메타데이터 동기화 및 관측성(Observability)

4.1 스키마 메타데이터 자동 동기화 (`metasync`)

SQLON은 데이터베이스 테이블 구조, 인덱스 현황 및 테이블/컬럼 Comment 정보를 지속적으로 캡처하여 메타 DB에 저장합니다.

```
# 수동 메타데이터 동기화 트리거
curl -X POST http://localhost:6767/api/meta/sync \
  -H "Authorization: Bearer SecureMasterToken2026!" \
  -d '{"profile_id": "pg_analytics"}'
```

4.2 플릿 헬스 체크 및 워크로드 모니터링

SQLON은 시스템 상태 점검 및 관측성 엔드포인트를 제공합니다.

엔드포인트	Method	역할	비고
<code>/healthz</code>	GET	Liveness & Readiness 점검	Load Balancer 헬스 체크용
<code>/api/fleet/instances</code>	GET	등록된 DB 인스턴스 상태 및 핑 현황	인증 필요
<code>/api/observability/sessions</code>	GET	현재 실행 중인 쿼리 세션 추적	롱 러닝 쿼리 감지
<code>/api/observability/locks</code>	GET	DB 락(Lock) 대기 현황 점검	블로킹 쿼리 탐지
<code>/api/observability/top-sql</code>	GET	자원 소비 상위 SQL 분석	성능 튜닝 지표

4.3 감사 로그 (Audit Log) 관리

모든 자연어 질의, 생성된 SQL, 실행 주체, 실행 시간 및 리스크 스코어는 `/app/data/metadb/audit` 경로에 암호화되어 기록됩니다.

WARNING

보안 정책 준수를 위해 감사 로그 디렉토리를 정기적으로 외부 저장소에 백업하고 minimum 1년간 보관하도록 백업 스케줄러를 구성하십시오.

5. 장애 조치 (Troubleshooting)

발생 장애	원인	문제 해결 절차
DB Connection Failure (DNS)	Docker 컨테이너 내 <code>localhost</code> 지정 오류	<code>localhost</code> 는 컨테이너 자신을 의미하므로 호스트 IP 또는 <code>host.docker.internal</code> 사용
Oracle Library Error (libclntsh.so)	Standard 이미지를 Oracle DB에 연결 시도	<code>sqlon-oracle:v0.1.2</code> 도커 이미지로 재배포

발생 장애	원인	문제 해결 절차
HTTP 401 Unauthorized	마스터 토큰 누락 또는 불일치	SQLON_ADMIN_TOKEN 값과 API 헤더 토큰 일치 여부 확인
MetaDB Disk Full	감사 로그 누적에 따른 디스크 부족	마운트 볼륨 디스크 용량 증설 및 오래된 감사 로그 아카이빙